

Fecha: 31 de Agosto del 2026

CNO 4: CIBERSEGURIDAD

ACTIVIDAD 5: Una página demasiado convinciente

Documentación

Maestro: Servando López Contreras

Alumno: Quetzal Olin Rodríguez Jiménez

Contenido

OBJETIVO DE LA ACTIVIDAD	3
DESCRIPCIÓN DEL ESCENARIO	3
CONFIGURACIÓN DEL LABORATORIO.....	4
Requisitos de Hardware y Software	4
Direccionamiento IP	4
Parámetros de Configuración en SET	5
EVIDENCIAS Y DESCRIPCIÓN DEL FUNCIONAMIENTO	5
Ejecución de SET y Configuración del Servicio	5
Interacción de la Víctima	5
Intercepción de Datos en Tiempo Real	5
EXPLICACIÓN DEL FLUJO DE LA CAPTURA DE INFORMACIÓN	6
CONTROLES DE SEGURIDAD PROPUESTOS	6
Controles Técnicos (Preventivos y Detectivos)	6
Controles Organizativos y Educativos	7
CONCLUSIÓN	7
REFERENCIAS	8

OBJETIVO DE LA ACTIVIDAD

El objetivo de la actividad es analizar el funcionamiento del Social-Engineer Toolkit (SET) dentro de un ambiente controlado de Kali Linux, con la finalidad de comprender cómo las técnicas de ingeniería social pueden ser utilizadas para simular escenarios de ataque y evaluar el nivel de exposición de un sistema o usuario ante este tipo de amenazas.

La práctica busca que el estudiante comprenda que la seguridad informática no depende únicamente de mecanismos tecnológicos como firewalls, antivirus, sistemas de detección de intrusiones o mecanismos de autenticación. El factor humano también representa un componente importante de la superficie de ataque. A través de SET es posible reproducir, dentro de un laboratorio autorizado, determinadas condiciones que pueden presentarse durante un intento de ingeniería social y observar el comportamiento del entorno frente a ellas.

De manera específica, la actividad pretende:

Identificar las principales características y funciones de SET.

Comprender el propósito de las herramientas de ingeniería social disponibles en Kali Linux.

Analizar el funcionamiento de una simulación de ataque en un ambiente aislado.

Observar qué información podría quedar expuesta cuando un usuario interactúa con un escenario malicioso.

Identificar los posibles efectos secundarios derivados de una simulación de este tipo.

Analizar la importancia del factor humano dentro de la seguridad de la información.

Proponer controles de seguridad capaces de reducir la probabilidad y el impacto de ataques de ingeniería social.

Relacionar los resultados obtenidos con principios de confidencialidad, integridad y disponibilidad de la información.

DESCRIPCIÓN DEL ESCENARIO

La presente práctica se desarrolló en un entorno virtualizado y controlado de laboratorio. El escenario simula un intento de ingeniería social dirigido a evaluar la credibilidad de portales web replicados y la susceptibilidad del usuario final frente a técnicas de recolección de credenciales (*Credential Harvesting*).

El ataque simulado utiliza **Social-Engineer Toolkit (SET)** sobre Kali Linux para clonar la interfaz de inicio de sesión de un servicio conocido (ejemplo: login de correo institucional o red social). El objetivo es observar el comportamiento del sistema cuando una víctima ingresa información sensible en una URL fraudulenta alojada dentro de la red local.

CONFIGURACIÓN DEL LABORATORIO

Para garantizar la seguridad y la aislamiento del experimento, se establecieron las siguientes especificaciones técnicas y parámetros de red:

Requisitos de Hardware y Software

- **Hipervisor:** VMware Workstation / VirtualBox.
- **Máquina Atacante:** Kali Linux (versión actualizada con paquete set instalado).
- **Máquina Víctima:** Windows 10/11 con un navegador web moderno (Google Chrome / Mozilla Firefox).
- **Segmento de Red:** Adapta de red configurado en modo **Host-Only** o **Internal Network** (sin salida a Internet externa para prevenir fugas de tráfico o alcance no autorizado).

Direccionamiento IP

- **Atacante (Kali Linux):** 192.168.1.50
- **Víctima (Windows):** 192.168.1.100
- **Máscara de Subred:** 255.255.255.0

Parámetros de Configuración en SET

1. **Vector de Ataque:** Social-Engineering Attacks $\rightarrow$ Website Attack Vectors $\rightarrow$ Credential Harvester Attack Method.
2. **Método de Clonación:** Site Cloner.
3. **IP del Listener:** 192.168.1.50 (IP local del atacante Kali).
4. **URL de Destino a Clonar:** https://example.com/login (Portal objetivo del laboratorio).

EVIDENCIAS Y DESCRIPCIÓN DEL FUNCIONAMIENTO

Ejecución de SET y Configuración del Servicio

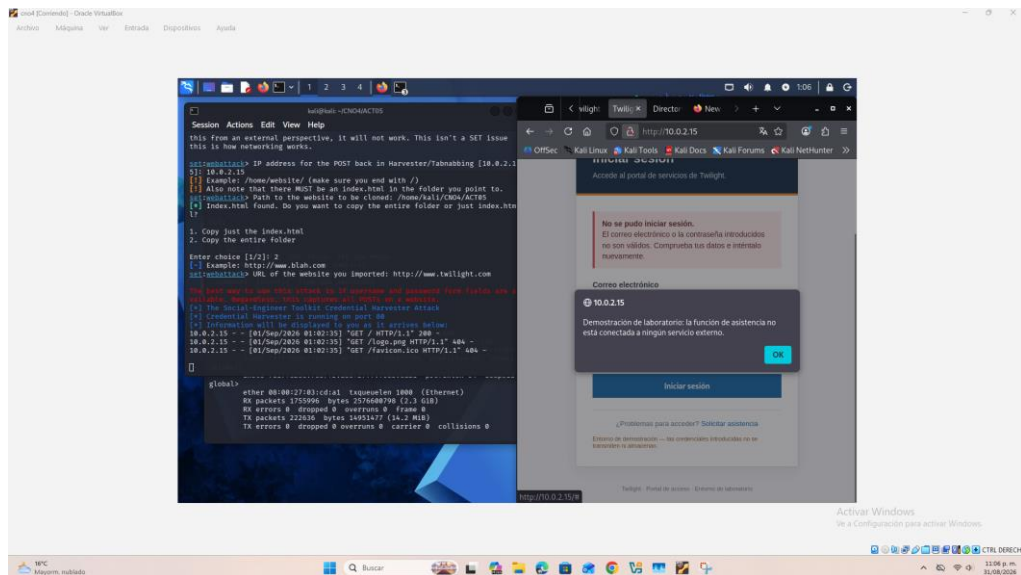
Se inició el toolkit desde la consola de Kali Linux mediante privilegios elevados:

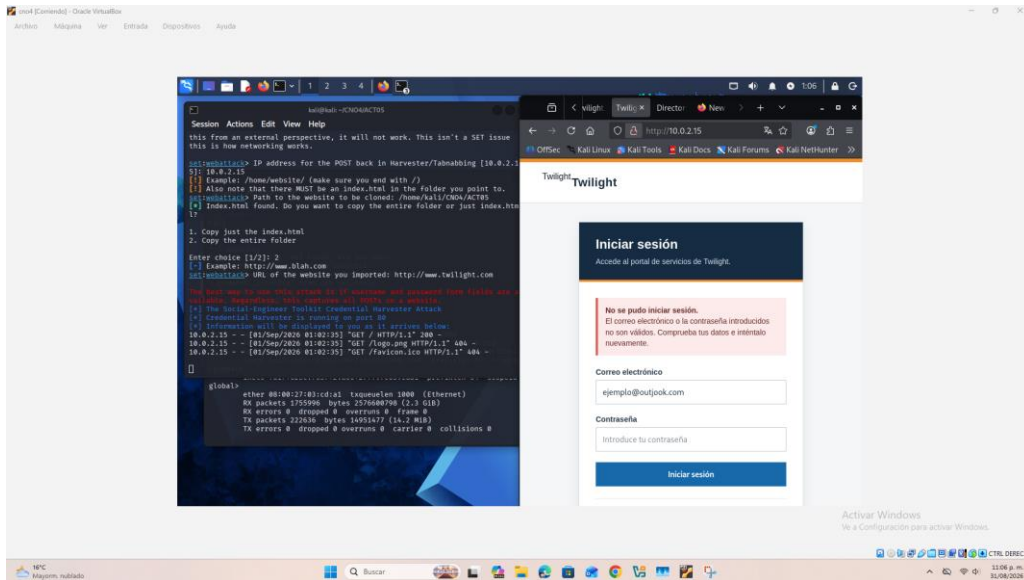
```
Bash
sudo setoolkit
```

Dentro del menú interactivo, se seleccionaron las opciones orientadas a la captura de credenciales mediante *web cloning*. SET desplegó un servidor web HTTP interno en el puerto 80 que replica la estructura HTML/CSS de la página origen e interrumpe el script de envío (POST) para interceptar la entrada de datos.

[+] Dynamic HTTP Server Created on port 80...

[+] SET Web Server is running... Waiting for victim to connect...





EXPLICACIÓN DEL FLUJO DE LA CAPTURA DE INFORMACIÓN

El proceso mediante el cual Social-Engineer Toolkit recopila y procesa la información sigue una secuencia de 5 etapas bien definidas:

1. **Clonación e Inyección:** SET descarga el contenido público de la URL elegida y reemplaza la acción del formulario `<form action="...">` para que apunte hacia la propia dirección IP del atacante en lugar del servidor legítimo.
2. **Despliegue del Servidor Falso:** SET inicia un servicio HTTP local escuchando en el puerto 80/443 esperando conexiones entrantes.
3. **Petición del Cliente (Víctima):** La víctima realiza una solicitud GET al servidor de SET. Se carga la página clonada.
4. **Captura y Almacenamiento:** Al presionar "Enviar", el navegador de la víctima realiza un método HTTP POST enviando la información estructurada en el cuerpo de la petición. SET intercepta esta solicitud, parsea las cadenas de texto coincidentes con campos como user, username, pass, password, y los escribe en pantalla y en logs locales (`/root/.set/reports/`).
5. **Redirección de Despistaje:** Para evitar sospechas, SET reenvía al usuario a la página web legítima original. La víctima suele asumir que cometió un error al escribir su contraseña en el primer intento.

CONTROLES DE SEGURIDAD PROPUESTOS

Controles Técnicos (Preventivos y Detectivos)

- **Autenticación Multi-Factor (MFA / 2FA):** Implementar esquemas basados en tokens FIDO2/WebAuthn o llaves físicas. MFA invalida las credenciales robadas en tiempo real ya que el atacante no posee el segundo factor.
- **Seguridad en Correo Web (SPF, DKIM, DMARC):** Configurar políticas estrictas para evitar el *email spoofing* o la suplantación de dominios de la organización.
- **Filtros de Contenido Web y DNS Sinkholing:** Bloquear el acceso a dominios de reciente creación o direcciones IP directas no categorizadas.
- **Gestores de Contraseñas Corporativos:** Evitan la inserción de datos en sitios clonados, ya que la extensión del navegador no autofill credenciales si la URL/dominio no coincide exactamente.

Controles Organizativos y Educativos

- **Programas de Concientización Continua:** Capacitar al personal en la identificación de indicadores de phish (URLs sospechosas, ausencia de HTTPS/certificados válidos, urgencia injustificada).
- **Simulaciones Periódicas de Phishing:** Evaluar métricas de rendimiento y tasa de clics de los empleados sin fines punitivos.
- **Procedimientos de Verificación:** Establecer canales alternativos para confirmar peticiones de información confidencial.

CONCLUSIÓN

El análisis práctico de Social-Engineer Toolkit (SET) demuestra que el factor humano continúa siendo uno de los eslabones más vulnerables y explotados en la cadena de seguridad de la información. La facilidad con la que un atacante puede replicar interfaces legítimas e interceptar credenciales evidencia que las soluciones tecnológicas —tales como firewalls o antivirus— resultan insuficientes si el usuario es persuadido para entregar voluntariamente su información de acceso.

Desde la perspectiva de los pilares de la seguridad de la información:

- **Confidencialidad:** Se ve gravemente comprometida al exponer llaves de acceso y datos privados a terceros no autorizados.
- **Integridad:** Corre el riesgo de ser alterada si el atacante utiliza las credenciales robadas para modificar registros o realizar transacciones no autorizadas.
- **Disponibilidad:** Se ve amenazada ante posibles bloqueos de cuentas, secuestro de servicios o ataques posteriores derivados del acceso inicial.

En última instancia, la ciberseguridad debe ser abordada de forma holística: la tecnología robusta debe complementarse con una cultura organizacional enfocada en la prevención, la duda metódica y la formación continua.

REFERENCIAS

Cybersecurity and Infrastructure Security Agency. (2023). *Avoiding social engineering and phishing attacks*. CISA. <https://www.cisa.gov/news-events/news/avoiding-social-engineering-and-phishing-attacks>

Mitnick, K. D., & Simon, W. L. (2002). *The art of deception: Controlling the human element of security*. Wiley Publishing.

National Institute of Standards and Technology. (2018). *Framework for improving critical infrastructure cybersecurity* (Version 1.1). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.CSWP.04162018>

Offensive Security. (s. f.). *Social-Engineer Toolkit (SET) package description*. Kali Linux Documentation. Recuperado el 31 de agosto de 2026, de <https://www.kali.org/tools/set/>

Open Web Application Security Project. (2021). *OWASP Top 10:2021 - A07: Identification and authentication failures*. OWASP Foundation. https://owasp.org/Top10/A07_2021-Identification_and_Authentication_Failures/

SANS Institute. (2022). *Security awareness roadmap: Building a mature awareness program*. SANS Security Awareness. <https://www.sans.org/security-awareness-training/>